

Tabla Comparativa de Resultados – OWASP ZAP

Comparación entre el análisis de seguridad inicial y el análisis posterior a las correcciones.

Alerta encontrada	Riesgo inicial	Corrección realizada	Resultado final
Cabecera Content Security Policy (CSP) no configurada	Medio — 5 casos	Se agregó una política CSP mediante .htaccess, permitiendo los recursos necesarios de la aplicación y Bootstrap desde cdn.jsdelivr.net.	Mitigada — pasó de 5 a 2 casos.
Falta de cabecera Anti-Clickjacking	Medio — 3 casos	Se agregó X-Frame-Options: SAMEORIGIN y frame-ancestors 'self'.	Corregida — ya no aparece en el informe posterior.
Cookie Sin Flag HttpOnly	Bajo — 1 caso	Se configuró la cookie de sesión con httponly => true.	Corregida — la cookie posterior contiene HttpOnly.
Cookie sin el atributo SameSite	Bajo — 1 caso	Se configuró la sesión con samesite => 'Lax'.	Corregida — la cookie posterior contiene SameSite=Lax.
Divulgación mediante X-Powered-By	Bajo — 4 casos	Se configuró expose_php = Off en PHP.	Corregida — X-Powered-By ya no aparece.
Divulgación de versión mediante Server	Bajo — 5 casos	Se configuró ServerTokens Prod y ServerSignature Off.	Corregida — posteriormente solo aparece Server: Apache.
Falta X-Content-Type-Options	Bajo — 3 casos	Se agregó X-Content-Type-Options: nosniff.	Corregida — la cabecera aparece en las respuestas posteriores.
Fuga de información en el Banner de la Página	Bajo — 2 casos	Se revisó la configuración del servidor y se redujo la información expuesta.	Corregida / no detectada en el segundo análisis.
Atributo de elemento HTML controlable por el usuario (XSS potencial)	Informativo — 2 casos	Se revisó como alerta informativa y se mantuvieron las validaciones y escape de datos existentes.	Informativa — continúa en el segundo análisis.
Respuesta de Gestión de Sesión Identificada	Informativo — 2 casos	No requiere modificación; corresponde a la detección de la cookie de sesión PHPSESSID.	Informativa — continúa como alerta informativa.
Inyección SQL	No detectada	Se verificaron manualmente los parámetros pagina=1, pagina=1 AND 1=1 -- y pagina=1 AND 1=2 --. Los	Falso positivo / Documentada — no se reprodujo una inyección real.

		tres produjeron el mismo resultado.	
CSP: Failure to Define Directive with No Fallback	No detectada	Se agregó CSP, pero ZAP identifica directivas sin una política de respaldo explícita.	No corregida / Pendiente de mejora — continúa como Medio, 4 casos.
CSP: script-src unsafe-inline	No detectada	Se permitió temporalmente 'unsafe-inline' para mantener funcionando el JavaScript existente.	Mitigada / Pendiente de mejora — continúa como Medio, 4 casos.
CSP: style-src unsafe-inline	No detectada	Se permitió 'unsafe-inline' porque la aplicación contiene estilos CSS integrados directamente.	Mitigada / Pendiente de mejora — continúa como Medio, 4 casos.

Resumen de los análisis

Informe inicial: 10 tipos de alertas, distribuidas en 2 de riesgo Medio, 6 de riesgo Bajo y 2 Informativas.

Informe posterior: 7 tipos de alertas, distribuidas en 1 de riesgo Alto, 4 de riesgo Medio, 0 de riesgo Bajo y 2 Informativas.

La alerta de Inyección SQL del segundo análisis fue verificada manualmente. Los valores probados para el parámetro pagina produjeron el mismo resultado, por lo que se documenta como falso positivo.